

IT-Sicherheit

Passwords in Windows

Prof. Dr. Johannes Freudenmann (DHBW Karlsruhe)

www.dhbw.de

Introduction

- Passwords Standard Method for Authentication
- How to Recover Passwords if lost or attack them
 - Guess or look while typing (keylogger)
 - Social Engineering
 - Brute Force
 - All combinations
 - Dictionary – Ramius Cracking Dictionary 4,14 GB
 - **CrackStation's Password Cracking Dictionary 15 GB**
(<https://crackstation.net/crackstation-wordlist-password-cracking-dictionary.htm>)

General things

- Hash is stored not the Password itself
 - PWD extended to 16 Byte (2x8 LMHash, NTHash)
 - MD5, 32 Byte long
- Brute force cracking trivial below 2^{30} Hashes to compute
- Brute force nearly impossible above 2^{50} Hashes.

Complexity of cracking a password

- 26 letters, 10 numerals, (special characters)
 - 62++ different possibilities for each char
 - 6 char long 56.800.235.584
 - 8 char long 218.340.105.584.896
- One PWD-Test (calculate a Hash) lasts
 - about 1 μ s on 1Ghz-CPU.
 - Much less with special hardware
 - All Hashes with 6 char 0,6574 d
 - All Hashes with 8 char 6,9235 a
- Calculate once: storage needed
 - Store Hash&Pwd. Sort hashes.
 - 6 char: 16+6 each entry: 1.250 GByte
 - Sorted, arranged by hash (ca. 40*60 Mrd Ops)
 - Find Pwd corresponding to hash immediately (40 Ops)

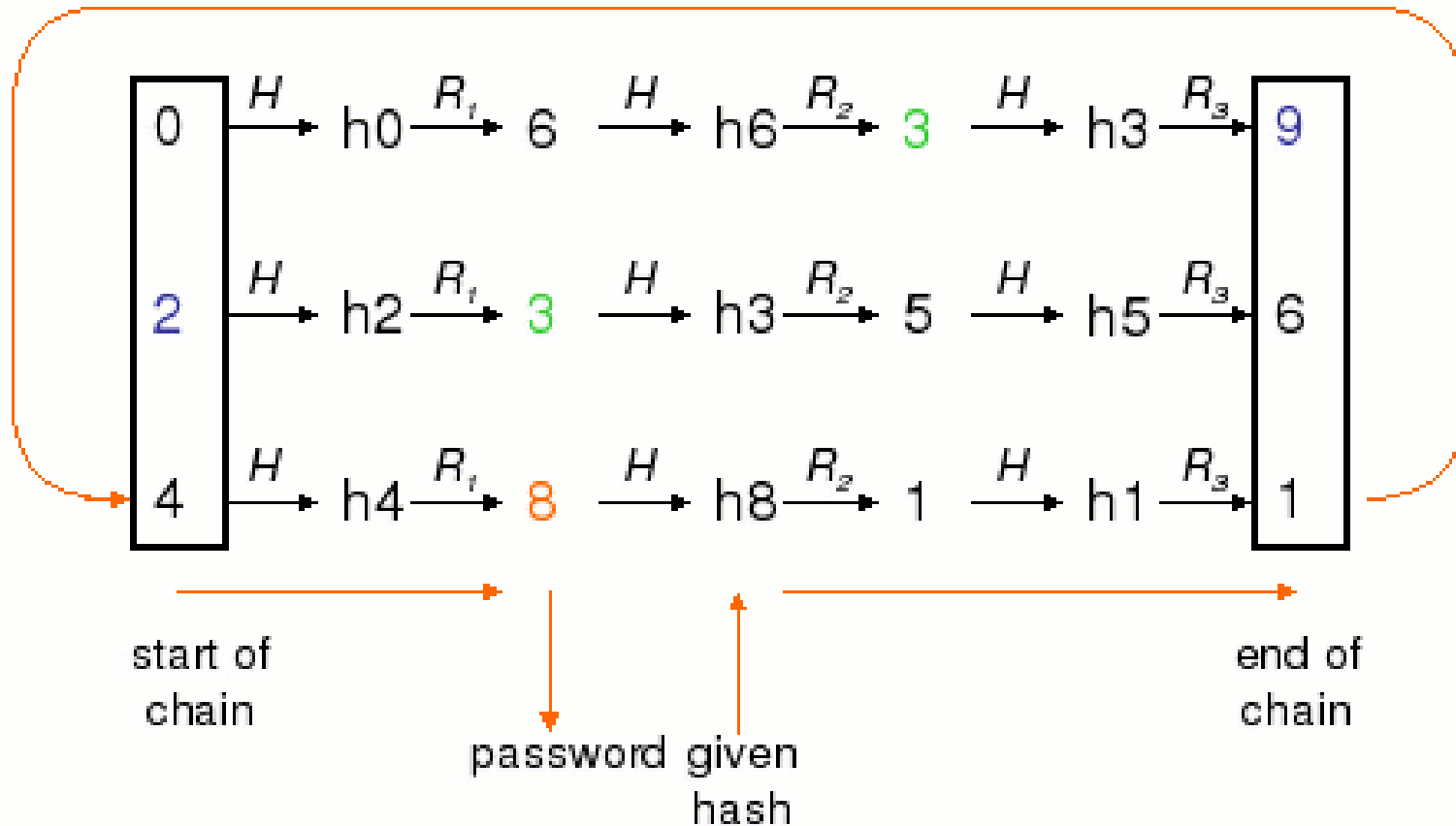
Example: Get a table of all Hashes

- Example: 6 char
- Time: 0,6574 d, disk storage: 1.250 GByte.
- Compute in parallel: 100 PC – 10 min.
- Every PC has about 13 GByte of data
- Network bandwidth: 180 Mbit/s

Problem memory resources

- >1 TeraByte not convenient to distribute.
- Too big even with only 6 chars.
- improvements:
 - Instead of HpHpHpHpHpHp -> H_spppppppH_e reduction to 30%, but more to compute
 - Rainbowtables: even more to compute but reduction of memory by an order of 10.000, **(time-memory-tradeoff)**

Rainbow-Tables



- Stored in memory only Start and End of chain.
- Chainlength about 10.000 values.
- Example Rainbow-Table for pwds 0..9

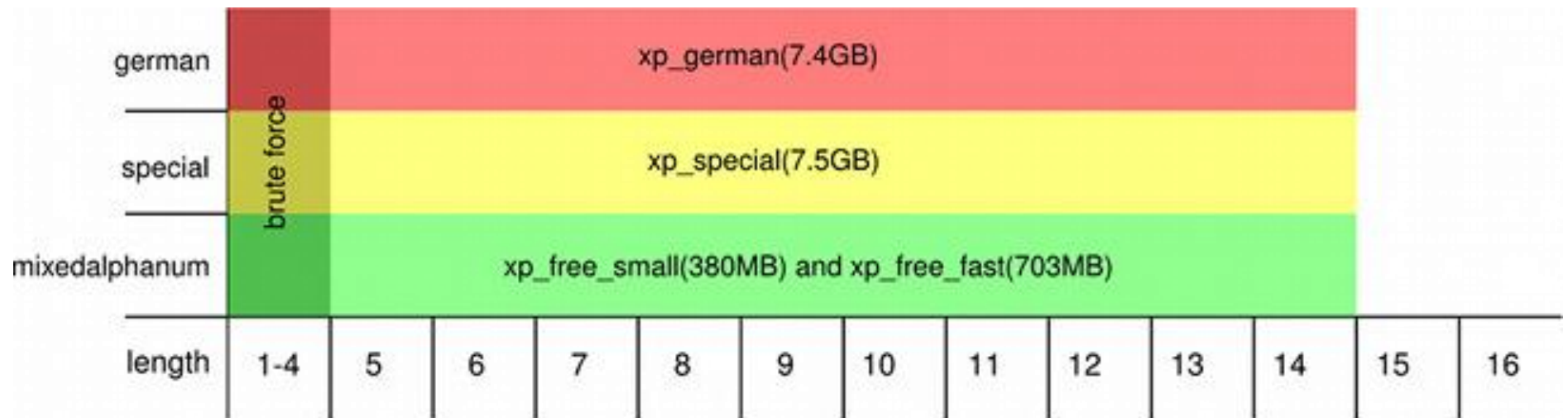
State: Rainbow-Tables (Oct 2013)

- LMHash (bereits vor Nov 2007) - complete
 - 29,2 GB – all PWD up tp 14 chars (2x 7)
(Upper, Lower, Numeric, 14 special symbols)
 - 38,8 GB (rar), 66 GB - all PWD up tp 14 chars
(upper, lower, numeric, 32 special symbols)
- MD5
 - 50,1 GB – all Pwd up to 6 chars (Nov 2007)
(upper, lower, numeric, 38 special symbols)
 - 13,4 GB – all Pwd up to 8 chars (Nov 2007, lower)
 - 86 GB - pwd up to 7 chars (Mai 2010)
(upper, lower, numeric, 32 symbols)
 - 1.049 GB - pwd up to 8 chars (Juni 2012)
(upper. lower, numeric, 32 symbols)
 - 1.009 GB - pwd up to 9 chars (Oct 2013, upper. lower, numeric)

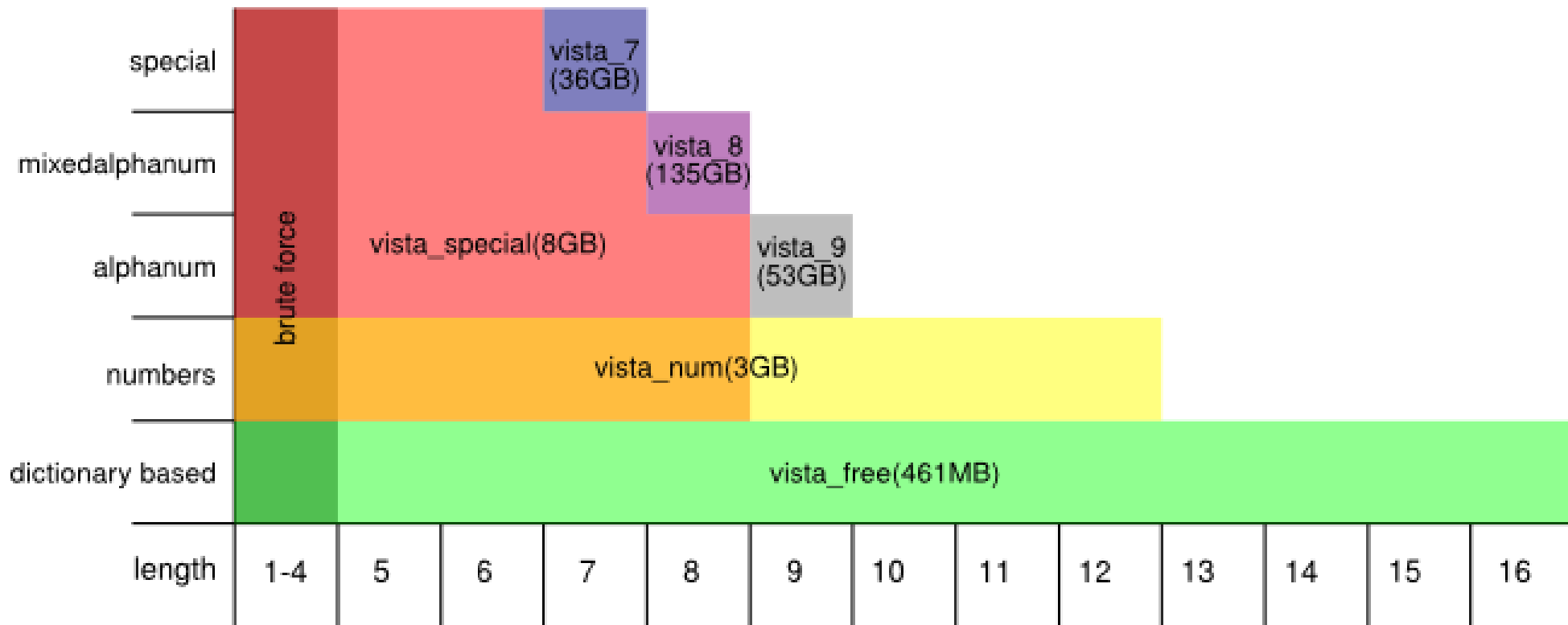
State Rainbow-Tables (Oct 2013) II

- SHA1
 - 36,9 GB – all Pwd up to 7 chars (Nov 2007, upper, lower, numeric)
 - 86 GB – all Pwd up to 7 chars (Oct 2013)
(upper, lower, numeric, special, space)
- NTLM (normal Hash of XP/Vista/Win7)
 - 123 GB – all pwd up to 9 chars (Nov 2007, lower, numeric)
Chain 50000
 - 135 GB - Pwd up to 8 chars (Mai 2010)
(upper, lower, numeric, space)
 - 1050 GB - Pwd up to 8 chars (Juni 2012)
(upper, lower, numeric, special, space)
 - 1009 GB - Pwd up to 9 chars (Oct 2013, upper, lower, numeric)
- Free Rainbow Project.
 - 5/2010: 417 PCs online, 1700 Ghz CPUs
6/2012: 2482 PCs, 18449 GIPS
10/2013: 3440 PCs, 16832 GIOPS

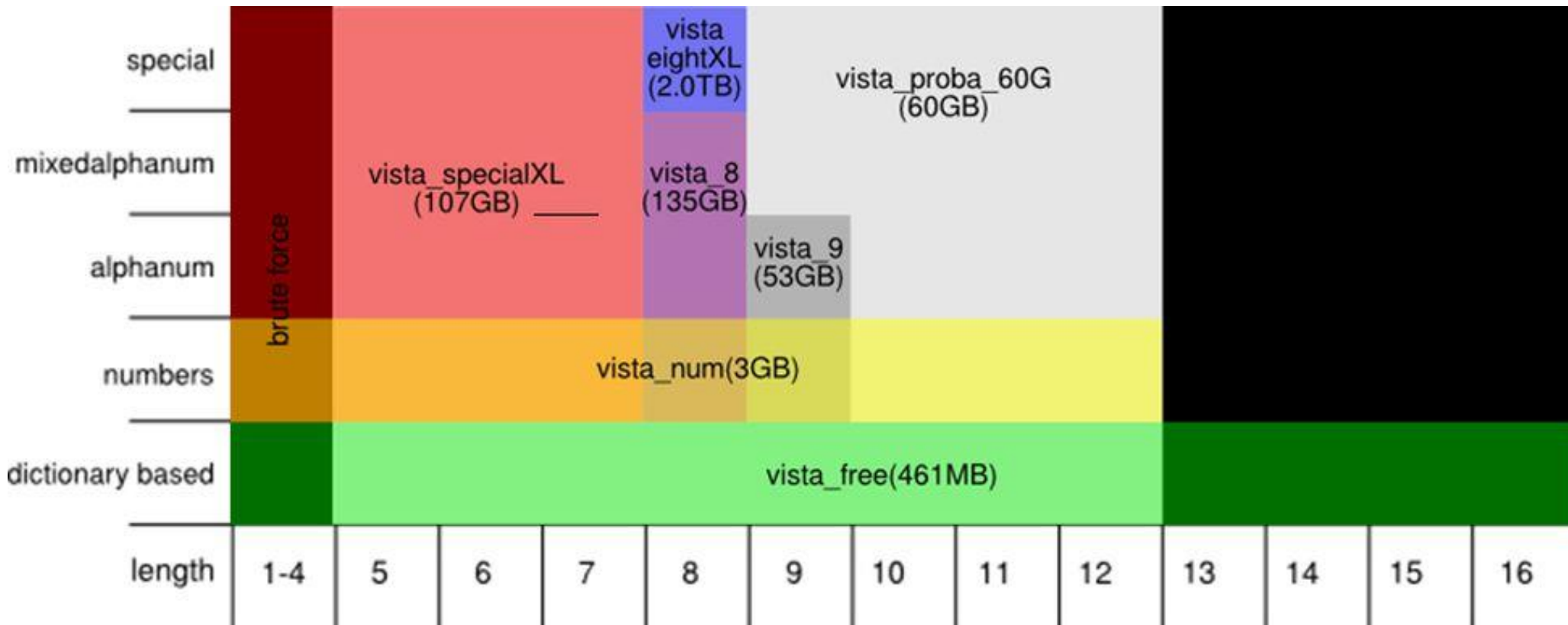
State III (Mai 2010)



State IV (Mai 2010)



State V (October 2013, Objective Securite)



Rainbow Tables – aktuelle Info.

- <https://project-rainbowcrack.com/index.htm>
- <http://project-rainbowcrack.com/buy.php>
- <http://project-rainbowcrack.com/buy.htm>
- <https://freerainbowtables.com/>

Demo

- s. Programm von Philippe Oechslin
 - Ophcrack 2.4.1
 - Upper/lower, numeric LMHashes
 - runtime max: 40 min (2400 sec)
 - 4 Tables altogether 388 MB
 - Chain length 10.000
- online example:
diverse...
<https://www.onlinehashcrack.com/>
- Generate pwd:
<http://www.tobtu.com/lmntlm.php>

Advice

- Don't use LMHashes.
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa\"no lmhash"=dword:00000001
- Build your Password
 - At least 9 characters, better 12 chars.
 - Upper **and** Lower **and** Numeric **and** Symbol.
 - Don't forget password and backup your data
 - Also be aware of
 - Social engineering
 - Key logger
 -

Password

- cracking time

Time it takes a hacker to brute force your password in 2025

Hardware: 12 x RTX 5090 | Password hash: bcrypt (10)

Number of Characters	Numbers Only	Lowercase Letters	Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters, Symbols
4	Instantly	Instantly	Instantly	Instantly	Instantly
5	Instantly	Instantly	57 minutes	2 hours	4 hours
6	Instantly	46 minutes	2 days	6 days	2 weeks
7	Instantly	20 hours	4 months	1 year	2 years
8	Instantly	3 weeks	15 years	62 years	164 years
9	2 hours	2 years	791 years	3k years	11k years
10	1 day	40 years	41k years	238k years	803k years
11	1 weeks	1k years	2m years	14m years	56m years
12	3 months	27k years	111m years	917m years	3bn years
13	3 years	705k years	5bn years	56bn years	275bn years
14	28 years	18m years	300bn years	3tn years	19tn years
15	284 years	477m years	15tn years	218tn years	1qd years
16	2k years	12bn years	812tn years	13qd years	94qd years
17	28k years	322bn years	42qd years	840qd years	6qn years
18	284k years	8tn years	2qn years	52qn years	463qn years



Password cracking time

Number of Characters	Numbers Only	Lowercase Letters	Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters, Symbols	Hardware
8	4 hours	10 months	219 years	896 years	2k years	RTX 4090
8	3 hours	8 months	172 years	703 years	1k years	RTX 5090x1
8	22 mins	1 month	23 years	93 years	246 years	RTX 5090x8
8	15 mins	3 weeks	15 years	62 years	164 years	RTX 5090x12
8	51 mins	2 months	52 years	212 years	559 years	A100 x8
8	34 mins	2 months	35 years	141 years	373 years	A100 x12
8	Instantly	1 hour	2 weeks	2 months	5 months	A100 x10,000 (ChatGPT 3)
8	Instantly	43 mins	1 weeks	1 month	3 months	A100 x20,000 (ChatGPT 4)

- *Max time required to crack randomly generated 8-character bcrypt work factor 10 password hashes of various complexity on different hardware.*

Quelle: <https://www.hivesystems.com/blog/are-your-passwords-in-the-green>

Situation in Linux

- Up to now no rainbowtables, because of salt
 - Salt: 12bit, 2 char.
 - Extend the length of the password.
 - 4.000x – 65.000x more expensive
- Password cracking time
 - Special hardware
Georgia-Tech: graphic cards cluster.
 - 8 char pwd less than 2 h (Sutter, 2010)
 - 12 char about 17.134 a.

Links

- <https://project-rainbowcrack.com/index.htm>
 - Nicht kostenlos!
- (Rainbow Tables der community
<https://freerainbowtables.com/>
Projekt eingestellt)